IKONPAY CCSS LEVEL-2 EVIDENCE REQUEST-1

CCSSA: Aniruddha Dhumal (AW7bDUoMwW3)
Organization: Plusnineone Security
Date: 27/02/2026

INTRODUCTION

The purpose of this request is to validate the architecture discussed in the preliminary interviews and to have concrete evidence to back up the claims. This is a preliminary evidence request and more requests might follow at the CCSSA's discretion. The nature of evidence can be documentation in form of policies and procedures, interviews with relevant personnel, inspections and observations of procedures.

EVIDENCE REQUEST

1. In the context of hot wallet key generation:
   a. A signed off architectural diagram of the automated signing agent supplemented with JIRA tickets showing the design phase.
   b. Screenshots of VPC route tables, ECS task definitions, CloudHSM policy reflecting FIPS config, mTLS certificate and NAT gateway rules implementing the outbound-only connection. Redact sensitive information.
   c. A Key ceremony checklist (runbook) that was followed. The runbook should be indexed, dated and mapped to the relevant key in the key inventory.
   d. A live walkthrough or a recorded screen/video demonstration of the Signer Service calling the HSM API in a staging/dev environment, showing the key generation call, the response and the HSM console showing the key was created within the HSM boundary.

2. In the context of warm wallet key generation:
   a. JIRA ticket or documented minutes of meeting to confirm that the vulnerable key was rotated out for a key generated on a new hardware wallet.
   b. Pictures of hardware wallets with serial numbers visible.
   c. Receipts to confirm that the wallets were procured from legitimate Ledger affiliated stores.

d. A Key ceremony checklist (runbook) that was followed. The runbook should be indexed, dated and mapped to the relevant key in the key inventory.
e. A live walkthrough or a recorded video of a non-production key rehearsal demonstration (dry-run) on a similar hardware wallet, following the same checklists used for production keys.

3. In the context of cold wallet key generation:
   a. Pictures of hardware wallets with serial numbers visible.
   b. Receipts to confirm the wallets were procured from legitimate Ledger affiliated stores.
   c. A Key ceremony checklist (runbook) that was followed. The runbook should be indexed, dated and mapped to the relevant key in the key inventory.
   d. A live walkthrough or a recorded video of a non-production key rehearsal demonstration (dry-run) on a similar hardware wallet, following the same checklists used for production keys.

4. Documented Key Generation and Wallet Policy.

5. Documented Key Management Technology Acceptance Review.

6. Threat model showing that single signer wallet risks were considered. Risk assessment and Risk treatment plans showing chosen controls and accepted residual risk.

7. Excerpts from the Safe application or a smart contract address for EVM chain confirming the multi-sig setup for warm and cold wallets.

8. Ledger Live log file from the sessions in which the genuine check was performed, opened and parsed through the Ledger log viewer at live.ledger.tools/logsviewer

9. Documented xpub derivation paths for BTC warm and cold wallets with access controls to verify that only the key holders are allowed to

access. This can be combined with the key inventory or could exist as a separate document linked to the key inventory.

10. Photographic evidence of where the multisig coordinator machine is stored between ceremonies (e.g., locked cabinet, safe, restricted-access room). To supplement this, an asset register showing the machine is registered as a dedicated custody device, not assigned to any employee for general use.

11. For the offline multisig coordinator laptop: A BIOS screenshot showing Wi-Fi and network adapters permanently disabled at firmware level.

12. Interviews with personnel handling the warm and cold wallet keys to ensure that the key generation process was followed according to the checklist.

13. For both BTC and EVM multi-sig wallets: A live walkthrough or recorded screen/video demonstration of a wallet recovery rehearsal (dry-run), confirming that the redundant key can participate in and complete a signing quorum.